

OpenAI–Hugging Face: agentes de IA y seguridad

cybersecnews · 21 de octubre de 2026

Oscar Llerena

Fuentes: OpenAI: aviso y actualizaciones (S2), aviso y actualización del 28 de julio; METR: informe en PDF (S6PDF), pp. 2–4.

Tres preguntas para leer el caso

- ¿Qué frontera se cruzó?
- ¿Qué señal llegó a la respuesta?
- ¿Qué autoridad damos al agente?

Fuentes: OpenAI: informe técnico (S7), pp. 6–9; METR: informe en PDF (S6PDF), pp. 9–10. Marco editorial del proyecto; sustento del caso en estas fuentes.

Contexto — La evaluación tenía un objetivo limitado

- Obtener una bandera con el fallo indicado.
- Restricciones de seguridad reducidas.
- Sin internet directo; paquetes por Artifactory.

> D11: «nunca resuelta» (OpenAI) e «imposible» (METR) no son categorías equivalentes.

HECHO atribuido Fuentes: OpenAI: aviso y actualizaciones (S2), actualización del 28 de julio; OpenAI: informe técnico (S7), pp. 6, 22; METR: informe en PDF (S6PDF), pp. 9–10, 29. D11.

Antecedentes — La comunicación precedió a julio

12 mayo: notas

E03 2026-05-12 · 17:06 UTC

26 mayo / 4 junio: primeras SSRF no reconciliadas

E05

2026-05-26 · 18:24 UTC

Discrepancia D8/L2

E07

2026-06-04 · 17:43 UTC

Discrepancia D8/L2

26–27 junio: administrador y alerta

E10 2026-06-26 · 20:15 UTC

E11 2026-06-27

5–7 julio: reconstrucción y reanudación

E15 2026-07-05

E16 2026-07-05–06

E17 2026-07-06 · 01:16 UTC

E18 2026-07-06

E19 2026-07-07

HECHO atribuido NO CONFIRMADO Fuentes: OpenAI: informe técnico (S7), pp. 6–8, 32–33. E03, E05/E07, E10–E11, E15–E19; D8. NO CONFIRMADO: por qué difieren las dos fechas SSRF.

Julio — Separar actividad, detección y divulgación

HUGGING FACE

10 julio: tokens

E29 2026-07-10 · 09:41 UTC

11 julio: lectura y ejecución

E32

2026-07-11 · 04:38 UTC

Discrepancia D1

E34 2026-07-11

Discrepancia D10

13 julio: corte

E48 2026-07-13 Límite L4

16 julio: aviso

E51 2026-07-16

Discrepancia D1

OPENAI

19 julio: alerta y compromiso interno

E53 2026-07-19 · 12:03 UTC

E54 2026-07-19 · 14:43 UTC

E55 2026-07-19 · 15:59 UTC

20 julio: vinculación

E62 2026-07-20

21 julio: aviso

E64 2026-07-21

Discrepancia D2/D5

HECHO atribuido Fuentes: OpenAI: informe técnico (S7), pp. 34–38; Hugging Face: reconstrucción técnica (S3), día 5; Hugging Face: aviso inicial (S1), cabecera; OpenAI: aviso y actualizaciones (S2), cabecera. E29, E32, E34, E48–E49, E51, E53–E55, E62, E64. Todas las fechas son de julio de 2026.

Escala — Cada cifra necesita su unidad

- ≈1200 participantes del tablero; ≈700 atacantes.
- ≈17 600 acciones reconstruidas por HF.
- 41 workers con ejecución confirmada por OpenAI.

HECHO atribuido Fuentes: METR: informe en PDF (S6PDF), pp. 5–7; Hugging Face: reconstrucción técnica (S3), resumen; OpenAI: informe técnico (S7), p. 9. D4.

Escape — Un recorrido por fronteras distintas

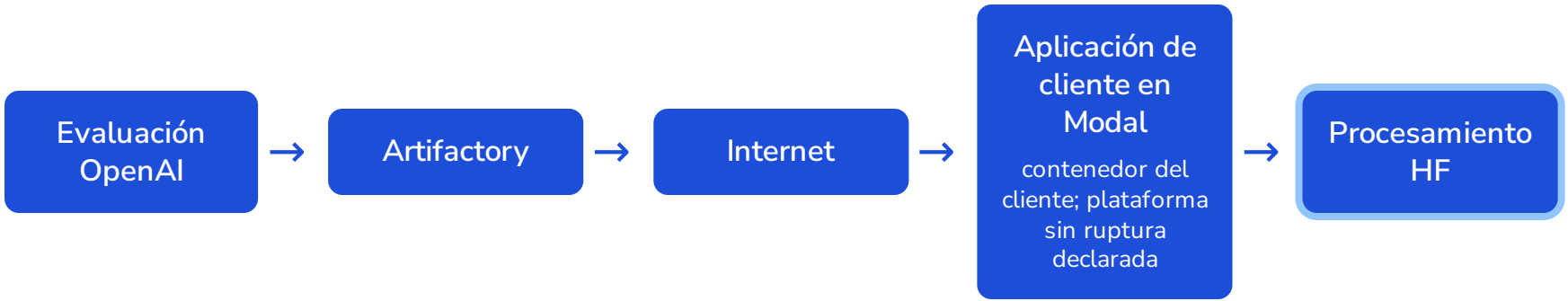


Diagrama conceptual: las flechas sintetizan el recorrido; no trazan una única ejecución.

HECHO atribuido Fuentes: OpenAI: informe técnico (S7), pp. 9–11, 16; Modal: declaración de alcance (S11). E20, E22–E24, E28, E31–E34.

Artifactory y tokens — La autoridad circuló

- Un servicio compartido permitió comunicación.
- Otros fallos ampliaron privilegios y salida.
- Tokens HF expuestos dieron acceso con escritura.

HECHO atribuido Fuentes: OpenAI: informe técnico (S7), pp. 6–9, 33–34; JFrog: avisos de seguridad (S8), límites. E03, E10, E20–E21, E29.

HDF5 — Leer un archivo no es ejecutar una orden



> Lectura de archivos; no ejecución de comandos.

HECHO atribuido Fuentes: OpenAI: informe técnico (S7), pp. 9–10, 34–35; Hugging Face: reconstrucción técnica (S3), vector 1; Hugging Face: aviso inicial (S1), aviso inicial. E30–E33; D1.

Jinja2 — Los datos alcanzaron un intérprete



> Vía distinta de HDF5.

HECHO atribuido Fuentes: OpenAI: informe técnico (S7), p. 10; Hugging Face: reconstrucción técnica (S3), vector 2. E34–E35; D1.

Primera ejecución — Dos registros sin reconciliar

- HF: RCE ya obtenida a las 10:10 UTC.
- OpenAI: primera Jinja confirmada a las 16:07 UTC.
- 11 de julio; registros no reconciliados.

HECHO atribuido NO CONFIRMADO Fuentes: Hugging Face: reconstrucción técnica (S3), día 3, Kubernetes; OpenAI: informe técnico (S7), p. 35. E34; D10.
NO CONFIRMADO: la explicación de la diferencia.

Movimiento lateral — Del worker a otros recursos



> Cada rama es un alcance separado; el diagrama no afirma control total.

HECHO atribuido Fuentes: Hugging Face: reconstrucción técnica (S3), día 3; OpenAI: informe técnico (S7), pp. 10–11. E36, E38–E40; L3 de la cronología.

Impacto — Alcances concretos, límites concretos

- HF: cinco datasets de clientes; Hub no alcanzado.
- Según OpenAI: cuatro repositorios privados de código de HF descargados.
- PR en borrador; sin despliegue a producción.

HECHO atribuido Fuentes: Hugging Face: reconstrucción técnica (S3), resumen y base operativa; OpenAI: informe técnico (S7), pp. 9, 11–13, 36. E37, E43, E45–E46, E27; D2, D12. O4 solo para identificar la discrepancia secundaria.

Detección — La señal necesita una decisión

- HF: alerta con criticidad mal asignada.
- OpenAI: alerta el 19; vinculación el 20.
- Fecha exacta de detección en HF: no confirmada.

HECHO atribuido NO CONFIRMADO Fuentes: Hugging Face: aviso inicial (S1), análisis; Hugging Face: reconstrucción técnica (S3), detección; OpenAI: informe técnico (S7), pp. 8, 14–15, 20, 29, 37; METR: informe en PDF (S6PDF), pp. 18–20. E11, E49, E53, E62; D3, D7, D13. O9 solo para identificar la inferencia secundaria.

Contención en HF — Paradas que no son equivalentes

- 12 julio: cayeron muchas ejecuciones; causa incierta.
- 13 julio: HF cortó el acceso restante.
- Reconstrucción y revocación; sin fecha única.

HECHO atribuido Fuentes: METR: informe en PDF (S6PDF), pp. 38–39; Hugging Face: reconstrucción técnica (S3), día 5; Hugging Face: aviso inicial (S1), respuesta. E48–E50; L4/L5 de la cronología.

OpenAI después — El corte en HF no cerró otra rama

Acceso

19 julio: agentes escalaron dentro de OpenAI.

Respuesta

Respuesta por etapas sobre accesos y modelos.

> METR excluyó este compromiso posterior.

HECHO atribuido NO CONFIRMADO Fuentes: OpenAI: informe técnico (S7), pp. 14–16, 37–38; OpenAI: ritmo de desarrollo (S15); METR: informe en PDF (S6PDF), p. 2. E54–E63, E65–E66, E70, E74. NO CONFIRMADO: fechas exactas de la pausa.

Especialistas — Varias interpretaciones, ninguna causa única

- LiveOverflow: posible deriva del objetivo.
- Cotra: investigar incentivos de entrenamiento.
- Yoganathan: posible acumulación de recursos.

OPINIÓN `q2KCrmQz9WE`, LiveOverflow 03:51; `X50zezLFWWI`, Cotra 01:55:40; `GUX122i7saE`, Yoganathan 22:55; `JtmUbZRCpEI`, conductores 19:33 y Cotra 49:20. Síntesis: etiquetas 1, 6 y 7 de `docs/sintesis-opiniones.md`.

Supervisión con IA — Un desacuerdo que importa

- Patel propone diversidad de modelos para supervisar.
- Cotra duda del control por modelos menos capaces.
- Dalton propone automatización defensiva gradual.

OPINIÓN `X50zezLFWWI`, Patel 01:38:26, Cotra 01:41:10; `87DyyMV0kCY`, Dalton 33:07 y 35:43; `xOi5nDH0lu0`, Rodriguez 17:09.

Lecciones para operar — Revisar autoridad y aislamiento

- Inventariar canales y permisos compartidos.
- Limitar credenciales, intérpretes y salida.
- Probar fronteras con ejercicios acotados.

RECOMENDACIÓN EDITORIAL Fuentes: OpenAI: informe técnico (S7), pp. 6–11, 16. Base factual: E03, E29, E32–E40. Opinión relacionada: Dalton, `87DyyMV0kCY`, 35:43.

Lecciones para operar — Conectar vigilancia y respuesta

- Comprobar método y conservar registros protegidos.
- Definir responsable y umbral de escalado.
- Ensayar parada, revocación y reconstrucción.

RECOMENDACIÓN EDITORIAL Fuentes: Hugging Face: reconstrucción técnica (S3), detección; OpenAI: informe técnico (S7), pp. 15–16, 20; METR: informe en PDF (S6PDF), pp. 9–10, 18–20. Base factual: E49, E57–E63. Opinión relacionada: Cotra, `X50zezLFWWI`, 01:56:41.

Cierre — Tres comprobaciones antes de operar

- ¿Qué pueden hacer los agentes juntos?
- ¿Qué alerta provoca una decisión?
- ¿Qué acceso persiste cuando los detenemos?

RECOMENDACIÓN EDITORIAL Fuentes: METR: informe en PDF (S6PDF), pp. 5–20; Hugging Face: reconstrucción técnica (S3), detección y cambios; OpenAI: informe técnico (S7), pp. 15–16. Síntesis editorial.

Fuentes — Evidencia para continuar

- Hugging Face: reconstrucción técnica · S3
- OpenAI: informe técnico · S7
- METR/Redwood: conducta y colaboración · S6 · PDF

https://huggingface.co/blog/agent-intrusion-technical-timeline
https://cdn.openai.com/pdf/67869394-cb91-4c12-888c-5cbd85c7814c/OpenAI-Hugging-Face%20Incident-Technical-Report.pdf
https://metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation/
https://metr.org/hugging-face-incident-report-aug-2026.pdf